

Cybersecurity Vulnerabilities using OWASP ZAP

ITECH 1502 Cybersecurity Fundamentals

Week 12 Final Project Report

Name: Khushi Tusharbhai Ajmeri

Student ID: 30473648

Summary

This project shows how to use OWASP ZAP in the TryHackMe AttackBox environment to do a basic web-application vulnerability assessment. The goal was to learn how to set up a local proxy, record website traffic, carry out active scanning and spidering, and produce a security report.

An Introduction to OWASP ZAP TryHackMe lab was launched, the browser proxy was set up to route through ZAP on port 8081, the target website was explored, and the tool's analysis of requests and responses was monitored. Even though there were no serious warnings from the scan, the exercise effectively demonstrated how to find and expose possible vulnerabilities.

The Detect and Respond functions of the NIST Cybersecurity Framework, which concentrate on tracking and analysing system vulnerabilities, are particularly connected to practical work through this activity. I gained practical experience and a deeper comprehension of automated vulnerability assessment tools overall from this exercise, which will help me in my future cybersecurity coursework and entry-level professional practice.

Introduction

Cybersecurity experts use OWASP ZAP, an open-source security testing tool, to find vulnerabilities in web applications. It functions as a proxy that intercepts and examines HTTP communication sent back and forth between a target server and a browser.

ZAP is free, industry-recognized, and user-friendly, which is why I chose it. It was accessible via our unit's secure training site, TryHackMe. Without risking actual systems, the OWASP ZAP room provided a supervised setting for practicing scanning techniques.

Due to its relevance to a real security tool, this project is relevant to cybersecurity education since it connects classroom concepts like vulnerability management, network defence, and incident response. I was able to watch the entire testing process, from gathering data to reporting.

Problems/Challenge

The primary task was to use ZAP's local proxy configuration to test a web application for vulnerabilities. To perform scans safely within the TryHackMe environment, route through ZAP, and capture requests, I had to configure the AttackBox browser.

The scenario in which a security analyst examines a client's website for potential security risks, like potentially harmful headers or cross-site scripting, is replicated in this exercise. The study also addressed the concepts of event response, which include identifying, recording, and presenting findings in an organized way.

Even though there were no major problems and the target location was straightforward, the true challenge was figuring out each step of the testing process and comprehending the meaning of the data.

Project Goals/Objectives

- Set up OWASP ZAP on the TryHackMe AttackBox as a proxy tool.
- Record and examine HTTP traffic flowing between the target website and the browser.
- To check for vulnerabilities, use ZAP's Spider and Active Scan functionalities.
- Gather logs and screenshots to support the assessment.
- Connect the exercise to incident-response guidelines and the NIST Cybersecurity Framework.
- Consider the abilities gained and the areas that require further development.

Methodology

Step 1: Environment Setup

I began the Introduction to OWASP ZAP session by logging into TryHackMe using my FedUni email, copied down the target IP address after starting the AttackBox virtual machine.

Step 2: Configuring the Proxy:

ZAP was opened, and the 8080 default proxy port was examined. Since it wasn't available, I used Tools -> Options -> Local Proxy to modify it to 8081. Set up the HTTP proxy 127.0.0.1:8081 in Firefox. Confirmed that "Main Proxy: localhost:8081" was shown by ZAP.

Step 3: Spidering and Traffic Capture:

ZAP automatically recorded the requests in the "Sites" tab when the target URL was browsed in Firefox. To find pages and parameters, right-click the target and choose Attack -> Spider.

Step 4: Active Scan:

Right-click the target once more after spidering, then select Attack -> Active Scan. ZAP tested for vulnerabilities automatically. After a few minutes of operation, the scan finished successfully.

Step 5: Reporting:

Used Report -> to create an HTML report. Create an HTML report. Zap_project_report.html is the saved file name. Screenshots of the proxy configuration, spider progress, scan status, and report summary were taken.

Results/Outcomes

The vulnerability assessment was completed successfully. After collecting every HTTP request, ZAP displayed the target site in the "Sites" tree. The Spider found several internal channels and resources to confirm that the proxy was functioning properly.

The Active Scan failed to identify any critical warnings, indicating that the test application was either too small or had no serious issues. Nevertheless, a successful "no alert" result shows that the testing process was properly configured and executed.

Reflection

This assignment taught me how vulnerability-scanning technologies, such as OWASP ZAP, identify potential vulnerabilities in web applications. By setting up the proxy, I was able to better grasp how HTTP queries and responses could reveal hidden dangers. I learned more about spidering and active-scanning techniques and how they apply to expert penetration-testing procedures. This task has also helped me better understand the NIST Cybersecurity Framework, particularly the Detect and Respond aspects. Overall, I felt more comfortable using cybersecurity theory in real-world situations and recording outcomes as proof of appropriate testing and system assessment.

I was able to see firsthand how cybersecurity technologies are applied in a practical environment thanks to this encounter. I gained knowledge on how to properly assess technical information, interpret scan results, and adhere to established assessment procedures. It strengthened my practical grasp of web-application security and improved my troubleshooting and analytical skills. The program also improved the participants' trust in their ability to operate Linux-based systems and interpret technical data, two skills that are helpful for jobs such as SOC analyst or junior security tester. It also helped me realize how crucial ethical testing and open disclosure of results are to an organization's security.

To observe actual vulnerabilities and compare severity levels, if I were to do this project again, I would test a more complicated target, such as OWASP Juice Shop or DVWA. Before scanning using ZAP, I would also try using other reconnaissance tools like Nmap or Nikto. I would therefore be better able to comprehend how vulnerabilities are found and validated. I would also spend more time learning manual interception in ZAP so that I could see how attackers change traffic. Overall, I would like to carry out more in-depth research and connect technical results to stronger repair suggestions.